UNIVERSIDAD PRIVADA DEL VALLE

FACULTAD DE INFORMATICA Y ELECTRONICA

CARRERA DE INGENIERIA EN SISTEMAS INFORMÁTICOS



Actualización del Test Plan en un entorno ágil – PedidoHub

Estudiante:

- Luis Andrés Suárez Andrade

Asignatura: Aseguramiento de la Calidad del Software (SQA)

Semestre: Sexto

Grupo: A

Santa Cruz – Bolivia

Auditor (QA Champion)	Luis Andrés Suárez Andrade
Fecha	28 de octubre de 2026
Objeto auditado	Código, pruebas y proceso de PedidoHub (rama `main`, copia SQA)
Criterios	Test Plan ágil v2.0, DoR/DoD (sección 6), buenas prácticas OWASP básicas, ISTQB v4.0
Método	Revisión estática del código, ejecución de la suite automatizada, sesiones exploratorias y revisión de la configuración

1. Resumen ejecutivo

Se auditaron 9 controladores, el servicio de reportes, los modelos, las vistas y la configuración. Se encontraron **6 no conformidades corregidas durante el sprint** (1 crítica, 3 mayores y 2 menores) y **4 observaciones que quedan como deuda técnica** priorizada en el tablero. Tras las correcciones, la suite automatizada pasa al 100 % (**216 de 216 pruebas**) y la cobertura de líneas de la lógica de la aplicación es de **81.3 %**.

Conclusión: el producto cumple los criterios de salida del sprint. El riesgo principal detectado (ausencia de autenticación) se corrigió con inicio de sesión, roles y bitácora de auditoría; queda pendiente cambiar las claves de demostración antes de cualquier uso productivo.

2. No conformidades y acciones correctivas

ID	Hallazgo	Severidad	Evidencia (cómo se detectó)	Acción correctiva	Prueba de regresión	Estado
DEF-01	Se podían registrar reservas nuevas con fecha pasada	Mayor	Revisión de `ReservasController.Create`; prueba roja	Validación `FechaHora >= ahora` solo para reservas nuevas	`Dada_una_fecha_pasada_…_se_rechaza`, E2E-07, Cypress	Cerrado
DEF-02	Crear o editar un pedido permitía dos pedidos sin facturar en la misma mesa (solo `AbrirRapido` lo impedía)	Mayor	Comparación de reglas entre acciones; prueba roja	Método `ValidarMesaLibreAsync` en Create y Edit	`Dada_una_mesa_con_pedido_sin_facturar_…`	Cerrado
DEF-03	Una factura podía emitirse con fecha anterior al pedido	Mayor	Análisis de valores límite; prueba roja	Validación `FechaEmision >= FechaHora del pedido`	`Dada_una_fecha_de_emision_anterior_…`	Cerrado

ID	Hallazgo	Severidad	Evidencia (cómo se detectó)	Acción correctiva	Prueba de regresión	Estado
DEF-04	No existía un endpoint de salud para monitoreo y CI	Menor	Revisión de requisitos de operación	`AddHealthChecks` + `/health` (verifica la BD)	`Health_Reporta_…`, Cypress	Cerrado
DEF-06	No existía autenticación ni control de acceso: cualquier visitante podía crear, editar o eliminar datos	Crítica	Revisión de arquitectura y de la configuración de seguridad	Login con cookie HttpOnly, claves con hash PBKDF2, política de acceso por defecto (todo requiere sesión), roles Administrador/Cajero/Mesero y bitácora de auditoría	`SeguridadTests` (24), `BitacoraTests` (7), E2E-12 a E2E-17, Cypress "Acceso, landing y roles"	Cerrado
DEF-05	Respuestas sin cabeceras de seguridad básicas	Menor	Revisión de configuración (OWASP)	Middleware con `X-Content-Type-Options`, `X-Frame-Options`, `Referrer-Policy`	`RespuestasHtml_IncluyenCabecerasDeSeguridad`, Cypress	Cerrado

Las pruebas de DEF-01 a DEF-05 se escribieron **antes** de la corrección (DEF-06 se cubrió con pruebas de aceptación al cerrar el incremento): 91 de 96 pasaban y los 5 fallos correspondían exactamente a estos defectos (`Docs/evidencias/tdd-fase-roja.txt`). Después de la corrección pasaron 96 de 96.

3. Observaciones (deuda técnica, no corregidas en este sprint)

ID	Observación	Riesgo	Acción recomendada	Responsable/plazo
OBS-01	Las cuentas de demostración usan una clave inicial documentada y no hay bloqueo por intentos fallidos	Medio	Cambiar `Seed:Clave` en cualquier despliegue y agregar bloqueo temporal por intentos	Dev/TD-01
OBS-02	Los listados no tienen paginación	Medio	Paginar pedidos, reservas y facturas; prueba de rendimiento	Dev/TD-02
OBS-03	Se cargan fuentes desde Google Fonts (dependencia externa y privacidad)	Bajo	Alojar las fuentes localmente	Dev/TD-03
OBS-04	`TelefonosController` tiene 51.4 % de cobertura; `ErrorViewModel` 0 %	Medio	Agregar pruebas de edición y rutas de error	QA/TD-04

ID	Observación	Riesgo	Acción recomendada	Responsable/plazo
OBS-05	Las pruebas de integración usan SQLite y producción usa SQL Server	Medio	Mantener E2E contra SQL Server en CI (ya configurado en `ci.yml`)	QA/continuo

4. Revisión de proceso

Aspecto	Resultado	Comentario
Pruebas escritas antes del código (TDD)	Cumple	Evidencia de fase roja y verde
Criterios de aceptación en formato Gherkin	Cumple	12 historias con criterios
Definition of Done aplicada	Cumple	Cobertura global 81.3 % (meta 80 %); `TelefonosController` (51.4 %) y `EmpleadosController` (60.5 %) quedan bajo la meta individual (TD-04)
CI configurado	Cumple	`.github/workflows/ci.yml` (aún no ejecutado en GitHub: el repo SQA no tiene remoto)
Independencia del revisor	No cumple	Equipo de una persona; mitigado con TDD y CI
Trazabilidad historia → prueba	Cumple	Columna de pruebas en `backlog-trello.csv`

5. Resultados de la verificación

Suite	Herramienta	Total	Pasadas	Falladas
Unitarias	xUnit	46	46	0
Integración y aceptación (BDD)	xUnit + WebApplicationFactory	134	134	0

Suite	Herramienta	Total	Pasadas	Falladas
E2E	Selenium WebDriver	17	17	0
E2E	Cypress	19	19	0
Total		**216**	**216**	**0**

Incidencias de ejecución (del propio proceso de pruebas): en la primera corrida de Cypress un escenario falló por un selector mal escrito en la prueba (no por la aplicación); al agregar el login, otra corrida falló porque faltaba definir el inicio de sesión en el archivo de pruebas. Ambos fallos eran de las pruebas y se corrigieron; no se ocultó ningún fallo.

6. Plan de seguimiento

- Sprint siguiente: TD-01 (endurecer claves y bloqueo de intentos) y TD-04 (cobertura).
- Repetir esta auditoría al cierre del sprint con las mismas métricas.
- Verificar que la suite del CI pase en GitHub tras publicar el repositorio.